

WELCOME
TO



Dublin25



+ • x

WITH MICROSOFT 365
AND AI

JOIN THE
CONVERSATION

#ESPC25



When AI Goes Rogue

Real-World Security Lessons from the Trenches

MIKA VILPO

AZURE LEAD ARCHITECT, NETOX OY, FINLAND

MIKA VILPO

IT GEEK BUILDING CLOUDS

@NETOX OY

LIKES TO TALK ABOUT IDENTITY, AUTOMATION AND SERVERLESS
25+ YEARS IN IT AND 15+ YEARS IN CLOUD

SPENDING FREE TIME AS RED CROSS VOLUNTEER IN
DISASTER MANAGEMENT, FIRST AID AND SEARCH & RESCUE

MIKA.VILPO@NETOX.COM

@MIKAVILPO 



What are we talking about?



- Securing End-User Interface
- Cloud Security Posture
- Missing Guardrails
- Identifying Rogue AI Solutions
- Provisioned Throughput
- Shadow AI in VMs

- Key takeaways

**Some scenes, names and details have
been dramaturgically enhanced to
protect the innocent**

**All demos are carefully recreated
reenactments of real-world scenarios**

Honey, I just created chat application

Case Study – Web-Facing Chat Application

Scenario:

A customer deployed a chat UI directly to the internet without any Web Application Firewall or API gateway

Setup:

Single public VM running the chat service

No publishing infrastructure (WAF, CDN, reverse proxy)

Case Study – Web-Facing Chat Application

Risks Identified:

- Unfiltered traffic leading to injection, scraping, and brute-force attacks
- No rate-limiting or bot protection
- All exploits hit the origin server directly
- Single VM in prone for SLA issues and needs maintenance

Lesson Learned – Secure the Edge

WAF	Limit	Protect	PaaSify
Always deploy a WAF (and/or API gateway) in front of any user-facing AI interface	Implement rate-limiting, IP reputation and bot-management rules to block automated abuse	Use CDN to absorb DDoS and filter out malicious traffic TIP: Front Door includes DDoS protection, Application Gateway does not	Use PaaS solutions, not VMs

Hey! Creating AI app is so easy!

Case Study – Open Storage & AI Services Exposed

Scenario:

Click...Click...Click...Done. I have now OpenAI services running in Azure.
YEY!

Setup:

OpenAI and AI Search with key authentication

OpenAI and AI Search used/usable via internet

Blob/File storage with public endpoints

Case Study – Open Storage & AI Services Exposed

Risks Identified:

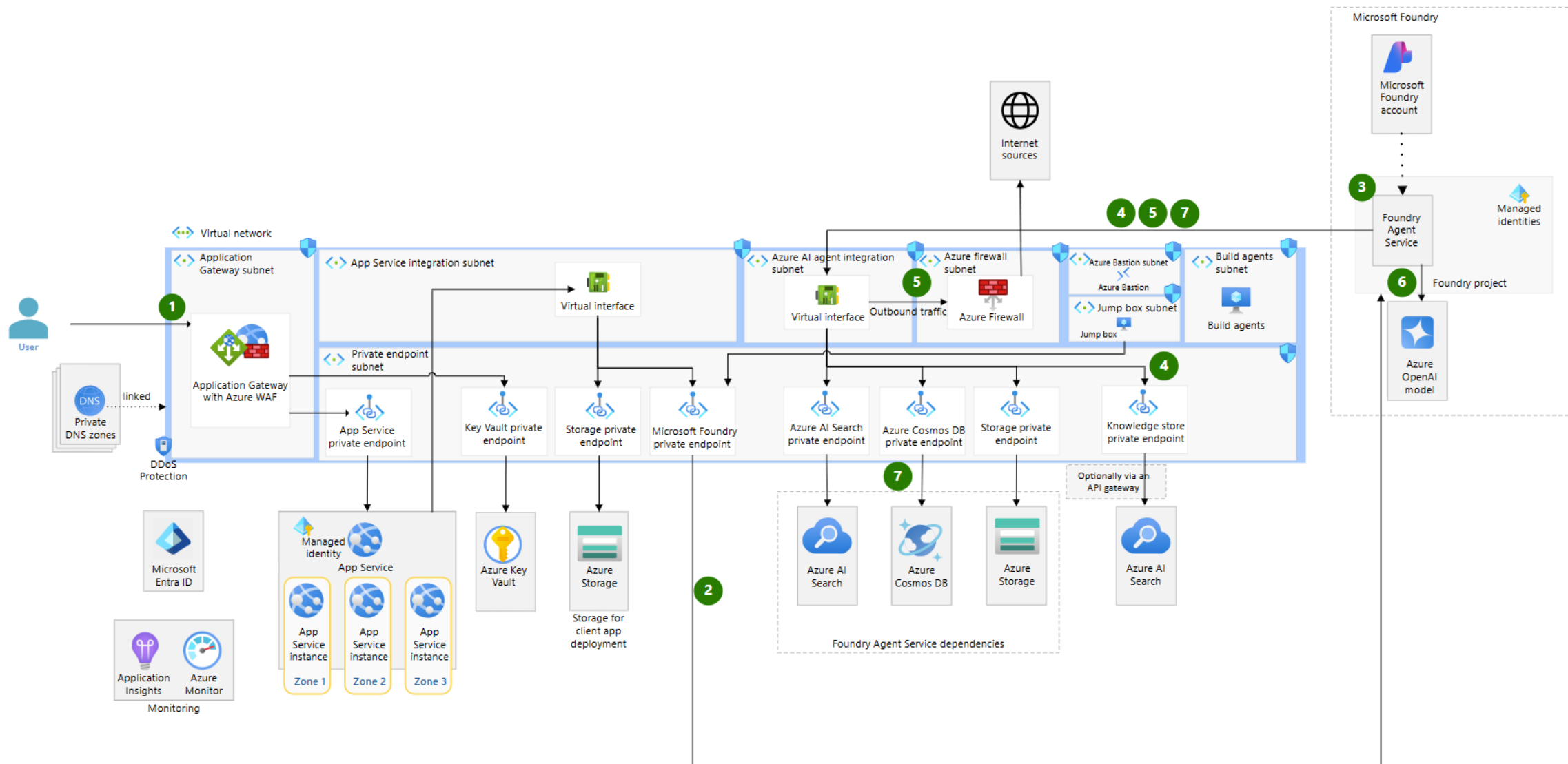
- Data exfiltration or tampering of storage blobs
- Unauthorized model queries increasing bill and leaking sensitive prompts
- Lack of IP restrictions or private endpoints

DEMO



Lock Down Service Endpoints

- Move storage and AI services into private VNet with service endpoints or private endpoints
- Restrict access via NSGs/Application Security Groups and firewall rules
- Enforce identity-based access (Managed Identities + RBAC) rather than keys (in code)
- Regularly audit any “public access” settings and remove when not explicitly needed



<https://learn.microsoft.com/en-us/azure/architecture/ai-ml/architecture/baseline-azure-ai-foundry-chat>

Guardrails?
... we don't need guardrails.

Case Study – Missing guardrails

Scenario:

We had data available in storage. Why can't we just use it for AI solution?
Default configuration must be ok.

Setup:

Out-of-Box AI solution – no content safety
Custom data as RAG-source
Data contains PII-information as it was not meant to be used in AI

Case Study – Missing guardrails

Risks Identified:

- Users can accidentally or intently use AI for bad purposes
- Prompt injection possible
- No monitoring on AI solution alerts
- PII information might leak

DEMO



Implement Guardrails

- Implement Content Safety – Prompt Shields
- Design System Prompt to fit application needs
- Use Defender for Cloud – CWP: Defender for AI services
- Educate for responsible AI use

<https://learn.microsoft.com/en-us/azure/ai-services/content-safety/>

**It's only for testing
... with real data.**

Case Study – Identifying Rogue AI Solutions

Scenario:

Governance policy required security evaluation before AI deployment, but Team A needed this!

Setup:

Ad-hoc AI prototypes spun up in production subscription
... without security review

Case Study – Bypassed Security Governance

Risks Actualized:

- Estate of AI applications is unknown
- Potential non-compliance with data protection standards
- Unvetted code and configurations running live
- Inconsistent use of secrets management

Detect Risks and Enforce Security

Defender CSPM:
“AI Security Posture Management”
“Data-aware security posture”
\$5/billable resource/month

Use Defender for Cloud CSPM

- Detect your AI applications and data sources
- Create process to process recommendations and observations
- Conduct routine compliance scans and report violations to leadership

Automate policy enforcement with tools like Azure Policy

Educate developers on the “why” behind governance to foster compliance

Defender for CSPM

- Two flavours: Foundational CSPM ja Defender CSPM
- AI Security Posture Management
- Data-aware security posture, Sensitive data scanning
 - Purview classification can enrich the alerts and context in CSPM

Plan details

Defender CSPM

Defender CSPM (Cloud Security Posture Management) offers advanced security posture capabilities from code to cloud for multi-cloud environments. Defender CSPM introduces an intelligent cloud security graph which empowers organizations to identify, prioritize, and mitigate security risks effectively. Defender CSPM complements the foundational security posture capabilities. [Learn more.](#)

Pricing: \$5/Billable resource/Month [learn more](#) ⓘ

- ✓ Agentless VM vulnerability scanning [Learn more.](#)
- ✓ Agentless VM secrets scanning [Learn more.](#)
- ✓ Attack path analysis [Learn more.](#)
- ✓ Risk Prioritization [Learn more.](#)
- ✓ Risk hunting with Security Explorer [Learn more.](#)
- ✓ Code-to-cloud mapping for Containers [Learn more.](#)
- ✓ Code-to-cloud mapping for IaC [Learn more.](#)
- ✓ PR annotations [Learn more.](#)
- ✓ Internet exposure analysis
- ✓ External attack surface management (EASM) [Learn more.](#)
- ✓ Permissions Management (CIEM) [Learn more.](#)
- ✓ Regulatory compliance assessments [Learn more.](#)
- ✓ ServiceNow Integration [Learn more.](#)
- ✓ Critical assets protection [Learn more.](#)
- ✓ Governance to drive remediation at-scale [Learn more.](#)
- ✓ AI Security Posture Management [Learn more.](#)
- ✓ Data-aware security posture, Sensitive data scanning [Learn more.](#)
- ✓ Kubernetes API access [Learn more.](#)
- ✓ Agentless code-to-cloud containers vulnerability assessment [Learn more.](#)
- ✓ API Security Posture Management (Preview) [Learn more.](#)

DEMO



**What does this "provisioned"
mean?**

It must be the right choice!

Case Study – Unmonitored Provisioned Throughput

Scenario:

During testing, AI services were configured with high provisioned throughput and left running, generating massive costs

Setup:

Provisioned throughput in OpenAI service

Fixed high RU/s (or vCore) settings on Cosmos DB / AI inference clusters for convenience

Case Study – Unmonitored Provisioned Throughput

Risks Actualized:

- Exorbitant monthly bills with zero active load
- **No budget alerts in place**
- No real knowledge what I'm about to do and what this will cost

Language Models, Provisioned
(PTU), GPT-4o-mini, 10 PTUs x 730
Hours, Pay as you go
~14 000 € / month

Implement Cost Control



Configure budget alerts, cost anomaly detection and spend caps in your billing account and/or subscription



Review billing dashboards regularly and set lifecycle policies on resource tiers



Use serverless or auto-scale tiers during dev/test to pay for only what's consumed



Schedule off-hours scaling down or shut-off of non-production environments

DEMO



VMs are good for AI too!

Case Study – Shadow VM AI Deployments

Scenario:

Developers installed AI runtimes on unmanaged VMs to “just get going,” skipping patching and baseline hardening

Setup:

Standard Windows/Linux VMs with AI libraries and model files

No image management or patch strategy

Managed identity used for connecting PaaS resources

Case Study – Shadow VM AI Deployments

Risks Actualized:

- Unpatched OS and dependencies vulnerable to CVEs
- No centralized inventory or patch reporting
- Compliance gaps and potential data breach vectors
- Estate of AI applications is unknown
- Attack path formed from unpatched server to other resources

DEMO



Standardize and Automate Stack Management

- Use cloud native services and tools with cloud managed version control and patching
- IF NOT POSSIBLE:
 - Provide approved base images with AI frameworks pre-installed and hardened
 - Enforce auto-patching, vulnerability scans and configuration management
 - Maintain a centralized inventory and enforce policy-driven lifecycle (build → test → prod)
 - Shift to container-based or PaaS offerings where possible to reduce surface area

I'm scared.

Is this happening to me too?

What should I do?



1. Implement **cost management** and alerts that are automatic and forecast based
2. Implement Defender for CSPM and **create process to handle recommendations and observations**
3. **Educate** yourself, your team, and developers for **responsible AI**

Questions?

... or stories of your own?

Thank you!



Please rate
this session
on the app

